

Data Privacy & Confidentiality Policy

Policy owner: Legal & Compliance | Applies to information handled across MedCore

Document ID	MC-LC-002
Version	2.1
Effective Date	01 September 2026
Review Cycle	Annual
Classification	Internal — Confidential

1. Purpose and Policy Statement

MedCore protects patient, employee, provider, vendor and business information throughout its lifecycle. Information must be collected, accessed, used, shared, stored and disposed of only for an authorized business or care purpose.

The policy establishes minimum controls for confidentiality, privacy, secure handling, disclosure and incident reporting across hospital and corporate functions.

2. Scope

This policy applies to employees, clinicians, trainees, contractors, consultants, temporary staff, volunteers and third parties who handle MedCore information. It covers electronic records, paper records, verbal communications, images, exported reports, removable media and cloud-hosted information.

3. Information Classification

Classification	Examples	Handling expectation
Restricted	Medical records, identity data, credentials, investigation records	Need-to-know access; approved systems; enhanced monitoring
Confidential	HR files, contracts, pricing, internal reports	Authorized business use; controlled sharing
Internal	Procedures, training material, operational communications	Internal distribution unless approved
Public	Approved public communications	May be shared externally in approved form

4. Permitted Use and Minimum Necessary Access

Access must be linked to a defined role and current responsibility. Users must not browse records merely because the system permits access.

Information should be limited to the minimum necessary for the task. Reports and exports must avoid unnecessary identifiers where an aggregated or de-identified view is sufficient.

Shared accounts are prohibited unless a system has an approved technical exception with compensating controls.

5. Disclosure and External Sharing

External disclosure requires an authorized purpose and the applicable approval or legal basis. Staff must verify the recipient before sending information.

Emailing restricted information requires an approved secure channel. Physical documents must be sealed, addressed correctly and transferred through an approved method.

Requests from law-enforcement, regulators, courts, insurers or other external parties must be routed to the designated Legal/Compliance contact when the required authority is unclear.

6. Storage, Retention and Disposal

Official records must be retained in designated systems according to the applicable retention schedule. Local desktop copies and removable-media copies should be avoided.

Paper records and electronic media containing restricted information must be securely destroyed or sanitised when disposal is authorized. A legal hold or investigation overrides routine disposal.

7. Privacy and Confidentiality Responsibilities

Role	Key responsibility
All personnel	Protect credentials, use approved systems, verify recipients, report suspected incidents.
Managers	Approve role-based access, reinforce training, review inappropriate access concerns.
IT / Information Security	Maintain technical safeguards, logging, access controls and incident response.
Legal & Compliance	Advise on regulatory obligations, disclosures, investigations and policy interpretation.
Records Management	Maintain retention schedules and controlled disposal processes.

8. Privacy Incident Reporting

Any suspected loss, misdirection, unauthorized access, inappropriate disclosure, stolen device, compromised account or accidental exposure must be reported promptly through the approved incident channel.

Personnel should preserve relevant evidence and avoid deleting or altering potentially relevant records. Incident classification, notification and remediation are coordinated by the responsible response teams.

9. Practical Do / Do Not Guidance

Do	Do not
Lock your workstation when unattended.	Leave patient or employee records visible to others.
Verify recipient, attachment and address before sending.	Send restricted data to personal email or unapproved storage.
Use approved systems and secure transfer methods.	Use shared credentials or another person's account.
Report suspected exposure promptly.	Investigate or confront others outside the incident process.

10. Review and Exceptions

Policy owners review this document at least annually and after material regulatory, technology or operational changes. Exceptions require documented business justification, risk review, compensating controls and approval by the designated authority.

Failure to follow this policy may result in access restriction, corrective action or other measures under applicable MedCore procedures.

Frequently Asked Questions

What should I do if I send information to the wrong recipient?

Report the event immediately through the approved incident channel and preserve the original message or evidence. Do not attempt to conceal or independently delete evidence.

Can I store work files on a personal cloud drive?

Not unless the service and use case have been explicitly approved. Use MedCore-approved storage instead.

Who decides whether an external disclosure is permitted?

The responsible business owner should consult Legal/Compliance when the authority, legal basis or disclosure conditions are uncertain.